

Security and Compliance → Domain 2

→ you also responsible for Network Traffic Protection that includes Security group Firewall Configuration

⊕ Installed software as you responsible for your app Code, installed Softwares and scan for and patch Vulnerabilities in your Code.

Quick quiz, who is responsible for what? ←

1. Firewall Configuration → you
2. DC Security ⊕ Physical building → aws
3. Encryption of EBS Volumes → you
4. Language Versions of Lambda → aws
5. Taking RDS DB Backups → you
6. update Firmware on EC2 → aws
7. Ensuring data is encrypted at rest → you
8. Managing Network Infrastructure architecture → aws
9. Patch guest os → you
10. physically destroying storage media → aws

Shared Responsibility # Model

Is a model that outlines your responsibilities vs AWS responsibilities when it comes to Security & Compliance.

→ AWS responsible for security of the cloud:

↳ protecting & securing infrastructure

⊕ Control who access to DC

⊕ Network Components

⊕ software [managed services like RDS, S3, ECS, lambda Patching os...]

→ Your responsibility for security in the cloud:

↳ how services are implemented and managing your application data ⊕

↳ [responsible for encryption] data

⊕ securing your account, API Calls, rotating Credentials, Restricting internet access...

⊕ Patching guest os

⊕ app security with [Identity and access management]

Shared security responsibilities

1. Patch management

2. Configuration management

3. Awareness & Training

AWS trains its employees

→ you train employees in your organization

EC2 shared Responsibility Model

→ you

- install app
- patch guest OS
- Security Controls

→ aws

- EC2 Service
- patch host OS
- security of physical server

AWS trust & safety

Team

abuse of AWS Resources

والتواصل بكون بطيئة من دول:

1. Contact team using [Report AWS abuse Form]

2. Contact via email [abuse@amazonaws.com]

Lambda shared responsibility Model

→ you

- security of code
- storage of sensitive data
- IAM permissions

→ aws

- Provides Lambda service
- upgrade Lambda language
- Provides Lambda endpoints
- OS & underline infra-dependencies
- Software dependencies

aws of lambda

← مقارنة ما بينا

Shield Standard [1]

provides Free Protection against
Common ⊕ Frequently attacks

Shield Advanced [2]

enhanced protection (كان من مميزات مراقبة)

⊕ access to AWS experts
with fee

↓
24/7 access
with experts

Shield Advanced لا تقدر فقط ال
Protection على كل ما ال Services

1. Cloud Front (WAF ال)

2. Elastic Load Balancer (WAF ال مع ال Application Load Balancer)
حديروا

3. Route 53 (الوجه في حصة ثانياً عشان امنع ال DDOS ال وادى حصة واحدة)

4. Global Accelerator

Shield in Real World لا وى

→ Shield Advanced will give
you Notification of DDOS attack

Via cloud watch metrics ⊕

you have access 24/7 to experts

[Real time notification] during the attack

Security Services *
Software based security tools

WAF

Web application Firewall

helps to protect your web
app from Common web
attacks like SQL injection &
Cross-site scripting.

→ (hacker targets you
with malicious scripts that
executes on your browser)
Can share your private info

لا حظ انت تقدر ت
WAF على كل ما من

1. Directly on EC2

2. on Cloud Front

3. Application Load balancer
عشان هو ال هيكله على ال instance

2. Shield
DDOS protection service

Shield Standard
is free

Shield advanced
is paid

ولكن

uses ML to detect unauthorized behaviour ⊕
detect threats

Guard Duty .5

Has Built-in detection for EC2, S3, IAM.

Actively reviews CloudTrail,
VPC Flow logs, DNS logs

(من الازم عند ML model detected لو في حركة
عزيبه وناساوا واولوا
access authorization من مسجول
ليه وهدفهم ان كذا في threat 6. يراقب الحركة
الغريبة دي لانه دائما بيتابع ال logs وال API
Calls (CloudTrail على)

Guard Duty in Real World

→ Detect unusual API Calls
in your account [as it evaluates
all API requests in your account
that are associated with common
techniques used by attackers]

Uncover and report vulnerabilities on EC2
Instances.

Agent of inspector has installed on
EC2 Instance, reports vulnerabilities
found and it checks for access
from internet, remote login,
vulnerable software versions...

Inspector .6

help to discover Macie .3
⊕ protect sensitive
data (using ML behind the
scene)

Evaluate S3 environment and
uncover personally identifiable
information (PII)

Macie in Real World

→ Discover Passport number,
Social Security number,
Credit Card number on S3.

assets, audit and evaluate
configuration of many AWS
services (مساعد تقييم
مساعد Config)

Config .4

Track configuration changes
overtime

Delivers configuration
history to S3

[Configuration history file on
S3]

Notifications via SNS of
every configuration change.

Config in Real World

→ record configuration changes
with EC2, you can view network
software, as configuration changes

→ It provides different ways to a user can login with to your application

manage users you have those using your application

Cognito provides building tools to help user sign-up or sign-in

Cognito in Real World

→ You need to add a social media sign in into your web app [sign in via Facebook or Google -]

Key Management Service

→ allow to generate & store keys for encryption
→ (the place where you store and control keys)

manage AWS encryption keys

CloudTrail logs

S3 Glacier

Storage Gateway

Encryption

KMS

keys

automatically enabled for certain services like

encrypted

Inspector in Real World

→ Identify unintended network access to an EC2 instance via detailed report

(Port انت ناسيو وسايه مفتوح ووسكرا)

offers on-Demand access to Security and Compliance reports.

[is a central repository for Security & Compliance reports from third-party auditors]

service organization .1 (SI) Control Report (SOC)

Payment Industry Report (PCI) .2

Artifact in real world

→ You need to access AWS certifications for ISO Compliance.

Cognito
مع الحسابات الفاتت
كانت بتزكن اكتب
مع الحسابات
وال resources

→ Cognito has control access to application that you build on AWS account
[provide s authorization and authentication for mobile & web app]

allow to
manage

and retrieve

Secrets like **passwords**, **keys**, **database credentials**,
API keys and more...

→ you can easily **Retrieve**, **manage**, **rotate**
your secrets

→ you can **encrypt** secrets at
rest using **encryption keys**

← ارسه قابيلن عليها

→ Secrets Manager **عنه**
integration with **RDS**,

Redshift, **DocumentDB**

(دانايز و داناويرهاوس)

Secrets Manager in RealWorld

→ Retrieve database credentials
you need for your application
code

KMS in RealWorld

→ Create **Encrypted**
EBS Volume
(you're able to specify
a KMS customer master
key).

← مو برو **Cloud HSM** 2.
for generate

encryption keys

و صي

→ use **hard ware dedicated**
module for generate a key

← وهنا انت اربطة
generate
and manage your **own**
keys (مست AWS زكسا كان
سجيد فيا KMS)

aws doesn't
even have
access to your
keys

Cloud HSM in realWorld

→ Meet Compliance for requirements
for data security by using
[dedicated hardware]
in the cloud

Secret-
Management #